

Chapter 10

Vulnerability Scanning Types

Internal vs External Scanning

External scans show only what an outside attacker can see

Internal scans reveal what a threat actor could exploit once inside the network

Always scan from both vantage points

Agent vs Agentless Scanning

Agents run on endpoints and report back — ideal for remote workforces

Agentless scanning uses a central server to scan all clients on the network

Credentialed vs Non-Credentialed Scans

Credentialed scans use authorized privileges for deeper, more intrusive checks

Non-credentialed scans run without user accounts — less intrusive, less depth

Active vs Passive Scanning

Active scanning probes systems directly — may trigger security alarms

Passive scanning monitors traffic silently — unlikely to trigger alerts

Network Mapping and Device Fingerprinting

Mapping scans build a complete inventory of all network devices

Fingerprinting identifies host operating systems and what each target is running

Chapter 10

Vulnerability Scanning Considerations

Vulnerability Scanning Process

Routine security activity

Identifies system vulnerabilities

Helps prioritize issues

Supports proactive defense

Scan Planning Considerations

Determine timing of scans

Identify stakeholders to notify

Coordinate across teams

Align with operations

Scan Planning

Can trigger security alerts

Impacts system performance

May disrupt operations

Requires awareness

Scan Scheduling

Define scan frequency

Run during off-peak hours

Reduce performance impact

Balance coverage and disruption

Severity Thresholds

Define level of concern

Low severity lower priority

High severity requires action

Determines alert response

Network Segmentation

Scan segments separately

Schedule by network area

Some systems isolated

Impacts scan capability

Regulatory Requirements

Define scan frequency

Control scan depth

Require compliance reporting

Enforce security standards

Chapter 10

Governance Frameworks

What Is Governance?

Governance defines how organizations are structured and operate

Key frameworks: PCI DSS, CIS Benchmarks, and ISO 27000

PCI DSS The Payment Card Industry Standard

Mandatory requirements for any business that stores or processes cardholder data

Non-compliance can mean losing the ability to accept credit card payments entirely

CIS Benchmarks Best Practices for Hardening

Recommendations from the
Center for Internet Security

Harden your network and reduce
your attack surface

ISO 27000 Series

Covers information security,
cybersecurity, and
privacy protection

Not mandatory, but often
required by partners handling
sensitive data

Policies and Governance

Policies are driven by best practices and past security incidents

Legal requirements like GDPR can shape governance and oversight roles

Exam Prep Tips

Expect PCI DSS questions on virtually every top-tier certification exam

CIS Benchmarks and ISO 27K are also common exam topics to watch for

Chapter 10

Vulnerability Scanning Response

Exploitability and Threat Actviity

Determine exploitability

Assess current threat activity

Check active exploitation

Consider external impact

Asset Value and Impact

Evaluate asset importance

Assess operational impact

Consider financial loss

Determine criticality

Remediation Availability

Check patch availability

Determine fix options

Assess corrective actions

Identify limitations

Scan Result Accuracy Types

True and false outcomes

Positive and negative results

Accuracy must be verified

Impacts decision making

True Positive and True Negative

True positive

- Vulnerability exists

True negative

- No vulnerability present

Both are correct results

Validate scanner accuracy

False Positive

Reported vulnerability not real

Incorrect finding

Wastes time and effort

Leads to unnecessary work

False Negative

Missed actual vulnerability

Incorrect absence of issue

Creates false sense of security

High risk outcome

Context in Scan Results

Meaning depends on context
Good vs bad varies by scenario
Interpret results carefully
Align with objective

Validating Remediation

Confirm fixes are effective

Reassess vulnerabilities

Ensure issue resolution

Validate corrective actions

Rescanning for Verification

Run scan again after fixes

Check if issue persists

Repeat if unresolved

Confirm remediation success

Testing Scanner Accuracy

Introduce known vulnerability

Verify detection capability

Confirm full coverage

Validate tool effectiveness

Vulnerability Scan Review

Routine security process

Requires critical analysis

Identify false results

Interpret findings correctly